What is the Cookie Sandwich Attack?

The **Cookie Sandwich** is an exploit technique used by attackers to steal sensitive `HttpOnly` session tokens without needing direct JavaScript access.

The Background:

- Normally, sensitive cookies (like login tokens) have an `HttpOnly` flag.
- This flag stops JavaScript (`document.cookie`) from reading the cookie, protecting it even if Cross-Site Scripting (XSS) exists on the site.

The Attack (Step-by-Step):

1. **The Meat (Target):** The user has a protected session cookie: `session=SECRET_TOKEN` *(HttpOnly - invisible to JS)*.
2. **The Bread (Injection):** Using an unencoded quote vulnerability or legacy cookie format (`$Version=1`), an attacker creates two normal cookies that wrap around the target:
   - Cookie A (Top bread): `junk="start_text` *(unclosed quote)*
   - Cookie B (Bottom bread): `end_text"` *(closing quote)*
3. **The Browser Sends the Header:** The browser arranges and sends all cookies together in a single line:

   HTTP
   ```
   Cookie: $Version=1; junk="start_text; session=SECRET_TOKEN; end_text"
   ```
4. **The Server Parser Gets Confused:** The backend server sees the first quote `"` and assumes *everything* until the second quote `"` belongs to `junk`.
5. **The Leak:** The server thinks the entire string `start_text; session=SECRET_TOKEN; end_text` is the value of `junk`. When the application prints or reflects `junk` anywhere on the page (like a username or search term), the hidden `SECRET_TOKEN` is printed in plain text for the attacker to steal.